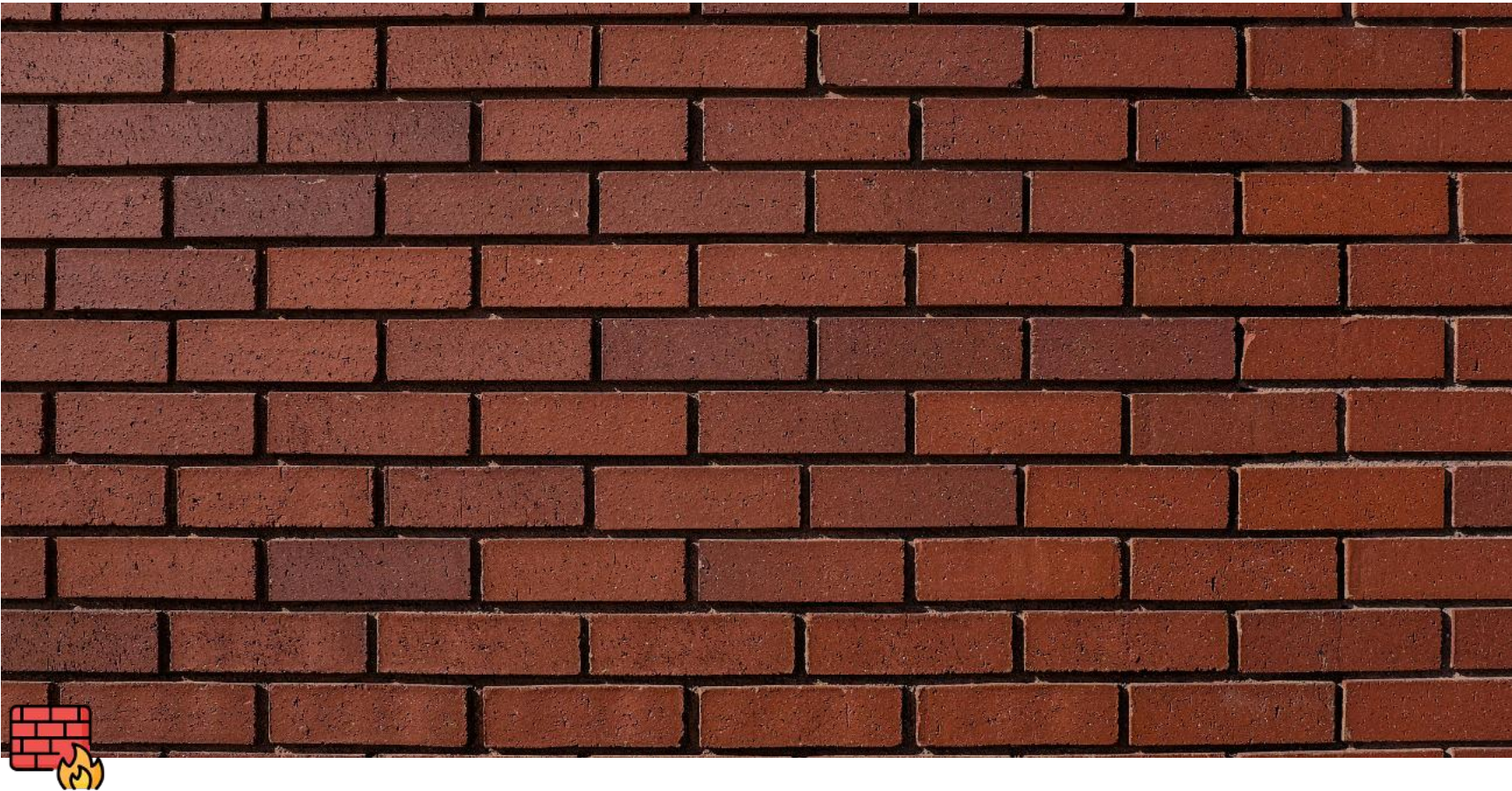




Par-feu applicatif pour Apache 2

📂 Catégorie	Sécurité
📅 Date	22 juillet 2026
📍 Lieu	Chez Moi
🕒 Mise à jour	22 juillet 2026 13:55
⚙️ Statut	Finalisée

ModSecurity est un pare-feu applicatif web (WAF) open-source. Contrairement à un pare-feu réseau classique (comme iptables) qui bloque des ports ou des adresses IP, un WAF analyse le contenu des requêtes HTTP. Il est capable de détecter et de bloquer des attaques complexes ciblant le code des sites web, telles que les injections SQL ou les failles XSS, avant même qu'elles n'atteignent l'application.

1. Installation des paquets

```
apt update
apt install apache2 libapache2-mod-security2 -y
```

Puis, vérifiez que le serveur web fonctionne en local (vous devriez obtenir le code HTML de la page par défaut) :

```
curl http://localhost/
```

2. Configuration du moteur de règles

Par défaut, ModSecurity est installé en mode "DetectionOnly" (il journalise les attaques mais ne les bloque pas). Nous allons l'activer pour qu'il bloque activement les menaces.

Renommez le fichier de configuration recommandé pour l'activer

```
sudo mv /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
```

Éditez ce fichier

```
nano /etc/modsecurity/modsecurity.conf
```

Trouvez la ligne **SecRuleEngine DetectionOnly** (souvent au tout début du fichier) et modifiez-la pour **SecRuleEngine On**

Puis redémarrez le service

```
systemctl restart apache2
```

3. Validation et fonctionnement

Effectuez une simple requête HTTP standard

```
curl -I http://localhost/
```

Résultats attendus :

- Apache répond avec un code HTTP/1.1 200 OK

Ensuite, tentons d'injecter une commande SQL classique dans l'URL

```
curl -I "http://localhost/?id=1'%20R%20'1'='1"
```

Résultats attendus :

- ModSecurity intercepte la requête malveillante. Le serveur renvoie un code HTTP/1.1 403 Forbidden.

Enfin, vous essayerez d'accéder à un fichier système critique via l'URL

```
curl -I "http://localhost/?file=/etc/passwd"
```

Résultats attendus :

- Encore une fois, ModSecurity intercepte la requête malveillante. Le serveur renvoie un code HTTP/1.1 403 Forbidden.

4. Consultation des journaux (logs)

Pour comprendre exactement pourquoi une requête a été bloquée, il faut consulter les logs d'erreur d'Apache. C'est ici que ModSecurity inscrit les détails de ses interventions

```
sudo tail -n 20 /var/log/apache2/error.log
```

Vous y verrez des ligne contenant **[client 127.0.0.1]ModSecurity : Acces denied with code 403**, suivies des explications sur la règle de sécurité qui a été déclenchée (ex : "SQL Injection Attack")